



CNO IV: Seguridad Informática

**ACT 09. LAB FILE PATH
TRAVERSAL
TRAVERSAL
SEQUENCES STRIPPED
NON-RECURSIVELY**

Fabiola Calvillo Galván 182455

Mtro. Servando López Contreras

Otoño 2026

LABORATORIO: FILE PATH TRAVERSAL TRAVERSAL SEQUENCES STRIPPED NON- RECURSIVELY

Introducción

Nombre del laboratorio: Traversal Sequences Stripped Non-Recursively

Nivel del laboratorio: Practitioner

Tipo de explotación: Es una vulnerabilidad que permite manipular una ruta de archivo proporcionada por el usuario para intentar acceder a archivos que se encuentran fuera del directorio que la aplicación pretendía permitir.

Objetivo del Laboratorio

El objetivo es demostrar cómo una validación incorrecta de las secuencias de traversal puede ser evadida.

En este laboratorio, la aplicación intenta eliminar las secuencias `../` de la entrada del usuario. Sin embargo, la eliminación se realiza una sola vez (no recursivamente). Esto permite construir una entrada que, después del primer filtrado, vuelva a contener una secuencia válida de traversal.

El propósito es conseguir que la aplicación lea un archivo ubicado fuera del directorio esperado.

Explicación Técnica del Laboratorio

El laboratorio presenta una vulnerabilidad de File Path Traversal debido a que la aplicación permite que un parámetro proporcionado por el usuario influya en la ruta de un archivo que el servidor intenta leer.

Para evitar este tipo de ataque, la aplicación elimina las secuencias `../` de la entrada. Sin embargo, el filtro funciona de manera no recursiva, es decir, solo realiza la eliminación una vez. Esto permite utilizar una entrada especialmente construida que, después de pasar por el filtro, vuelva a generar una secuencia `../`.

De esta manera, es posible evadir la validación y acceder a archivos ubicados fuera del directorio originalmente permitido. El laboratorio demuestra que eliminar directamente determinadas cadenas no es suficiente para proteger una aplicación contra Path Traversal.

Explotación

La explotación consiste en evadir el filtro que elimina las secuencias de Path Traversal. La aplicación intenta eliminar ../ de la entrada proporcionada por el usuario, pero lo hace únicamente una vez.

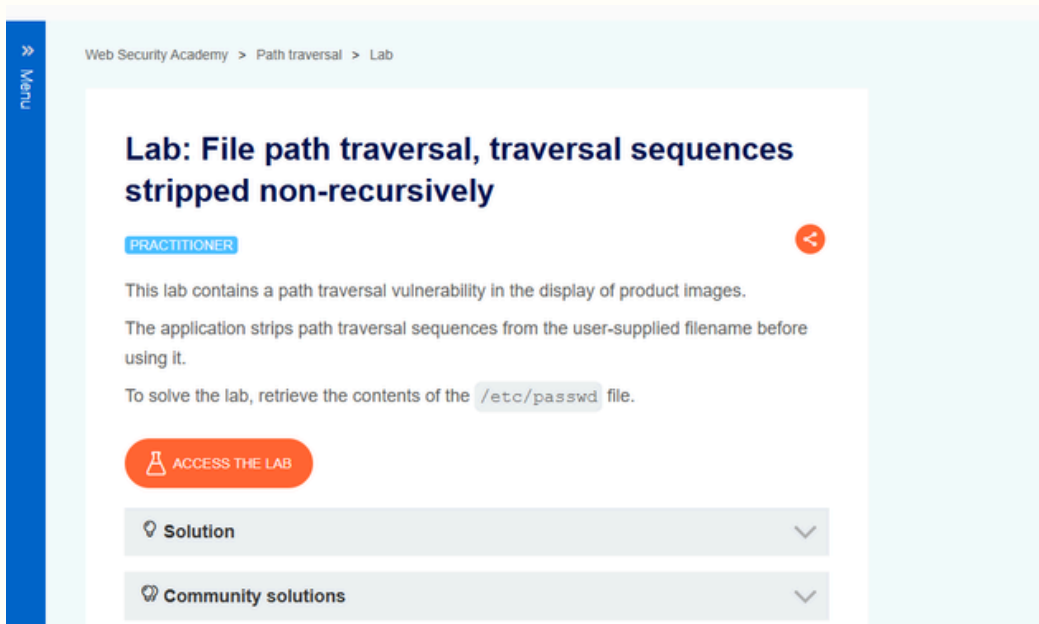
El atacante aprovecha este comportamiento utilizando una secuencia de traversal codificada de forma que, después de que el filtro elimine una parte, vuelva a quedar una secuencia válida ../. Esto permite modificar la ruta que procesa el servidor y acceder a un archivo que se encuentra fuera del directorio destinado para las imágenes.

En el laboratorio, la explotación se realiza mediante el parámetro utilizado para cargar la imagen, sustituyendo el nombre normal del archivo por una ruta especialmente construida. El resultado demuestra que el filtro puede ser evadido debido a que no realiza una segunda revisión de la entrada.

Resultado de la explotación: se consigue que la aplicación lea un archivo ubicado fuera del directorio permitido, confirmando la existencia de la vulnerabilidad File Path Traversal.

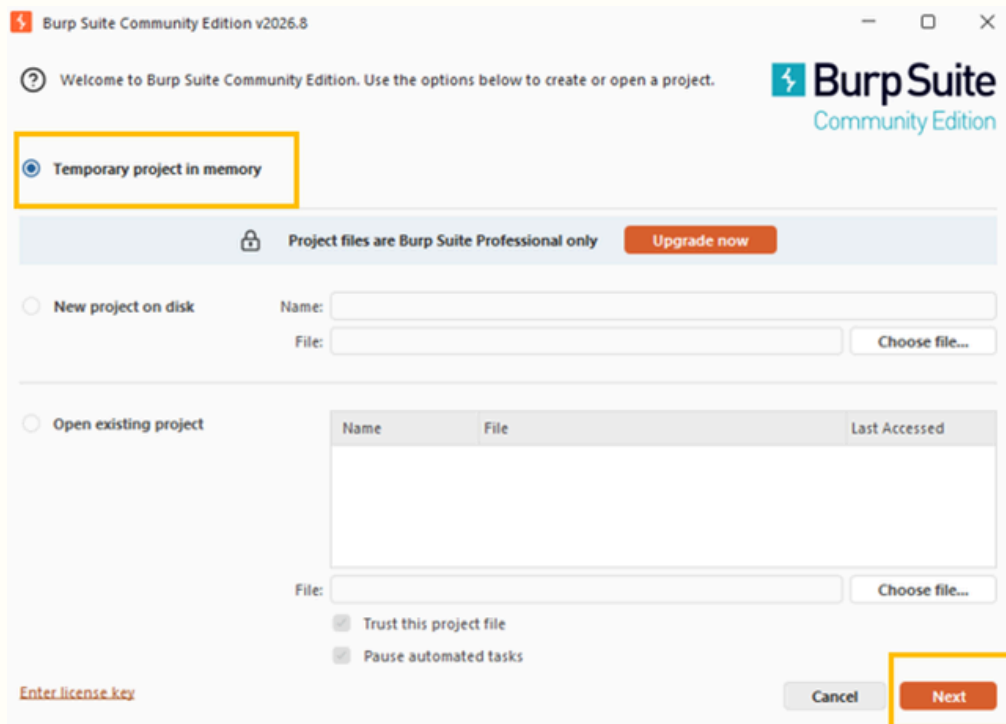
Procedimiento paso a paso

Como primer paso debemos ingresar a la página en donde accederemos al laboratorio, para después acceder a BurpSuite.

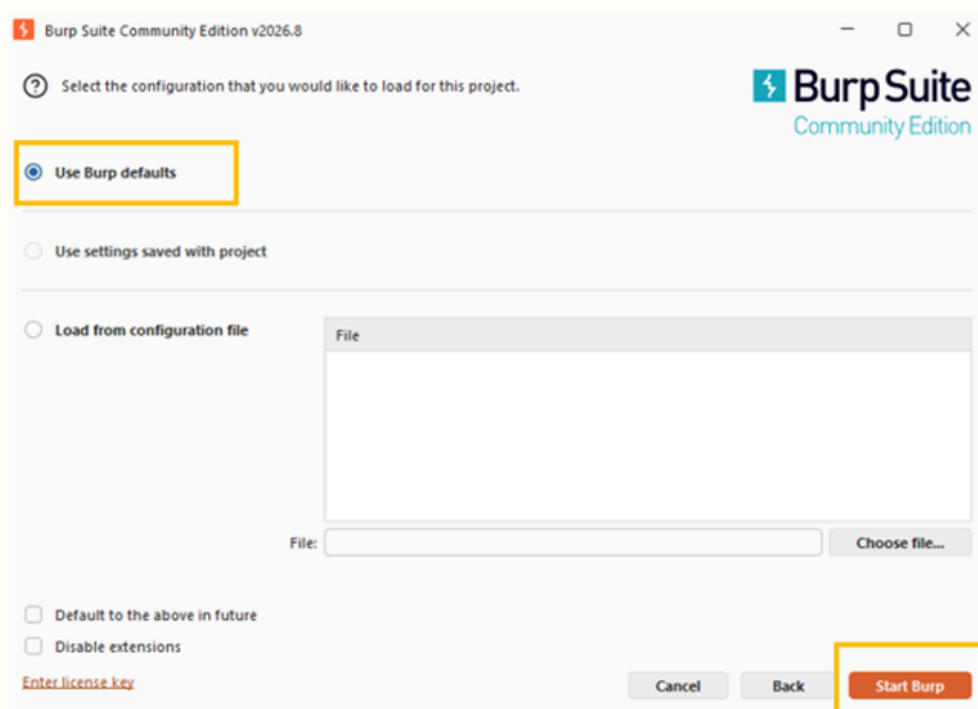


The screenshot shows the 'Lab: File path traversal, traversal sequences stripped non-recursively' page on the Web Security Academy website. The page has a blue sidebar with a 'Menu' button. The main content area has a light blue background. At the top, the breadcrumb 'Web Security Academy > Path traversal > Lab' is visible. The lab title is 'Lab: File path traversal, traversal sequences stripped non-recursively'. Below the title is a 'PRACTITIONER' badge and a red 'X' icon. The text describes the vulnerability: 'This lab contains a path traversal vulnerability in the display of product images. The application strips path traversal sequences from the user-supplied filename before using it. To solve the lab, retrieve the contents of the `/etc/passwd` file.' There is an orange button with a flask icon and the text 'ACCESS THE LAB'. Below this are two expandable sections: 'Solution' and 'Community solutions', both with a downward arrow icon.

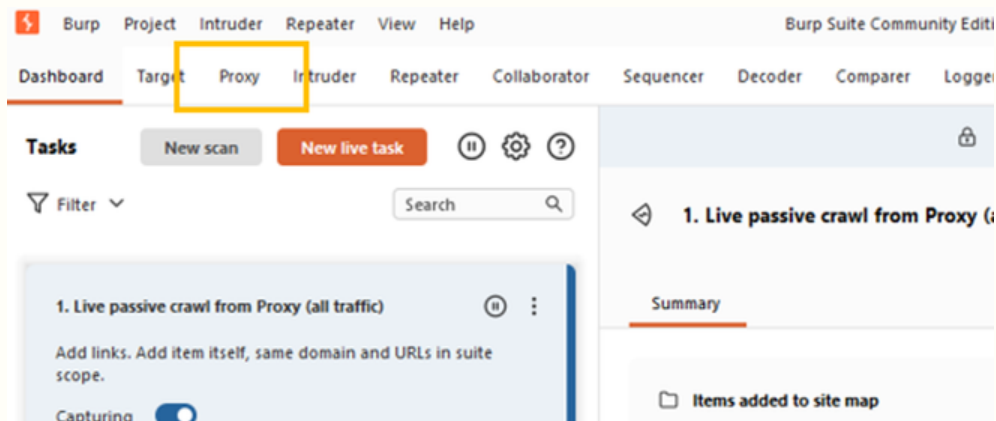
Una vez que accedimos a BurpSuite, nos aparece una ventana para poder iniciar la configuración, viene en la configuración por default que es **Proyecto Temporal en Memoria**, por lo que dejamos así la configuración, para después dar clic en **Siguiente**.



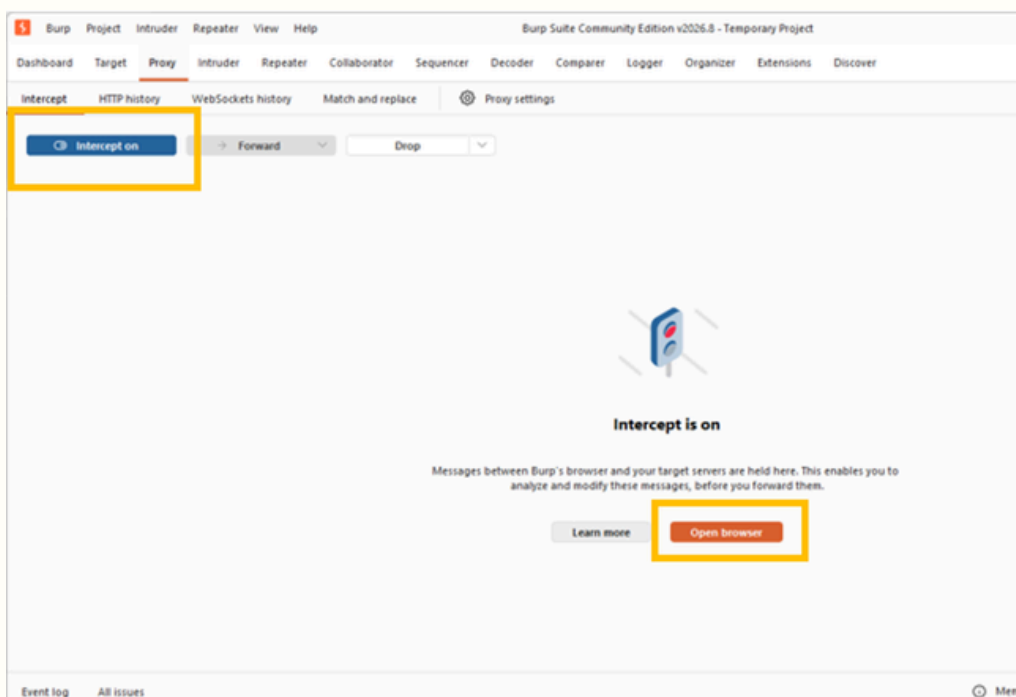
Continuando con la configuración, se mostrará la siguiente página en la que se muestra si queremos utilizar la configuración que ya nos da BurpSuite o si utilizaremos una configuración de algún proyecto pasado. Dejaremos la configuración que nos da por default y damos clic en **Siguiente**.



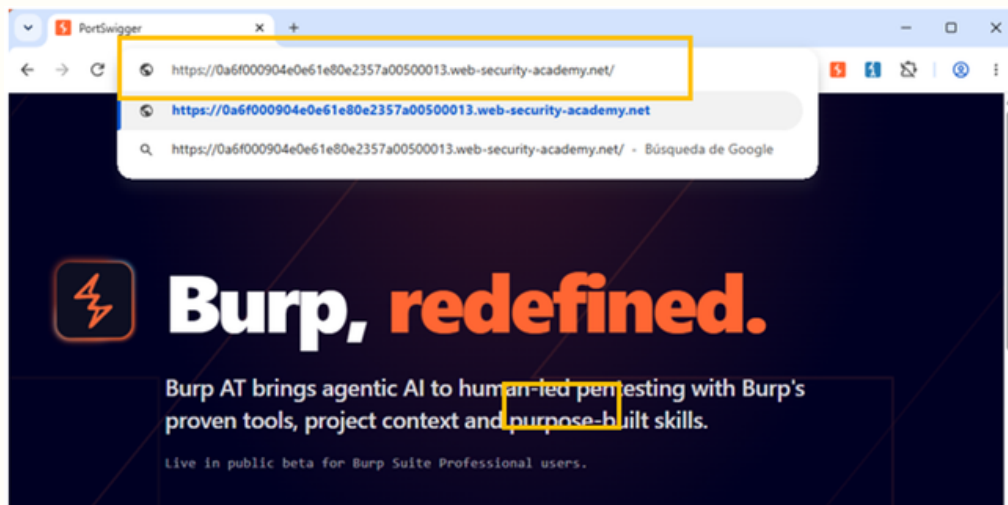
Ahora, ya que terminamos la configuración de BurpSuite, se nos muestra la página principal del sistema, por lo que ahora debemos movernos a la pestaña de **Proxy**.



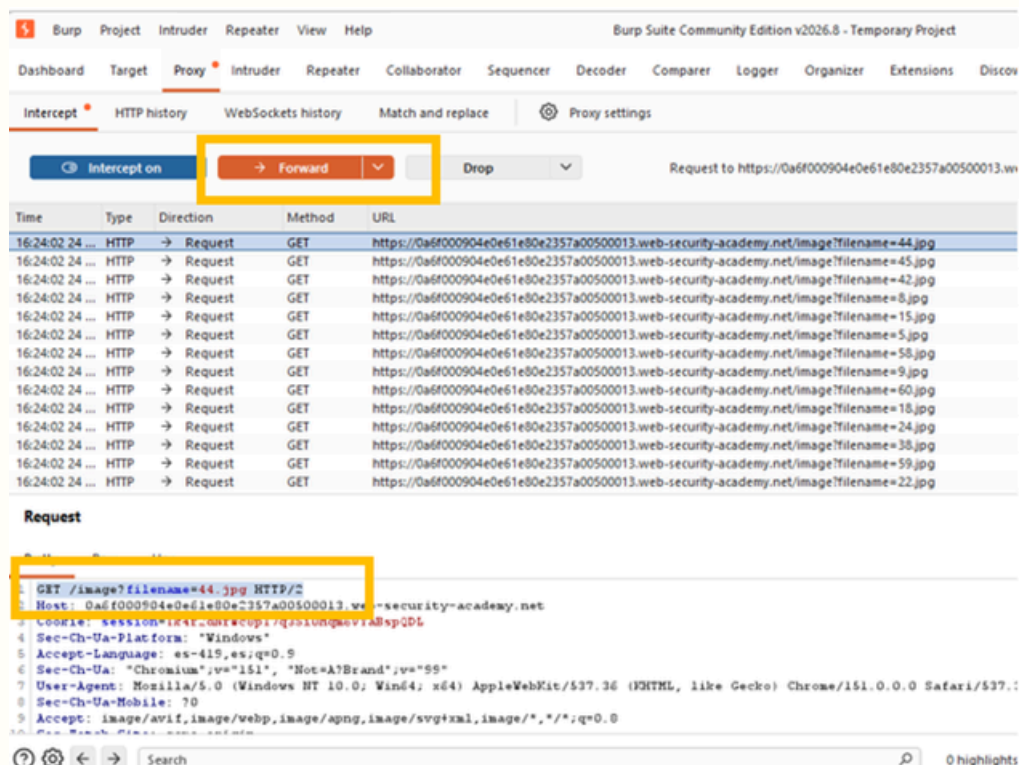
Ya estando en la pestaña de **Proxy** podemos observar que el **Intercept** está apagado, por lo que debemos encenderlo y debemos de dar clic en **Abrir Navegador**.



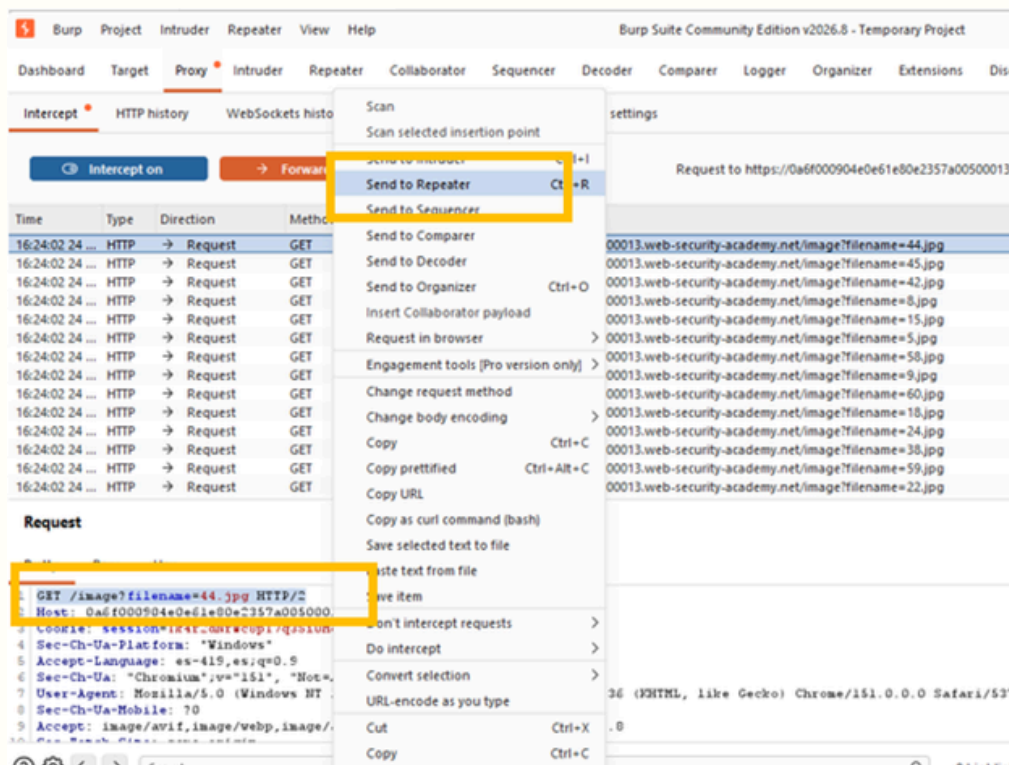
Al abrir el navegador, debemos de ingresar el enlace para poder abrir nuestro laboratorio, para poder realizar toda la práctica.



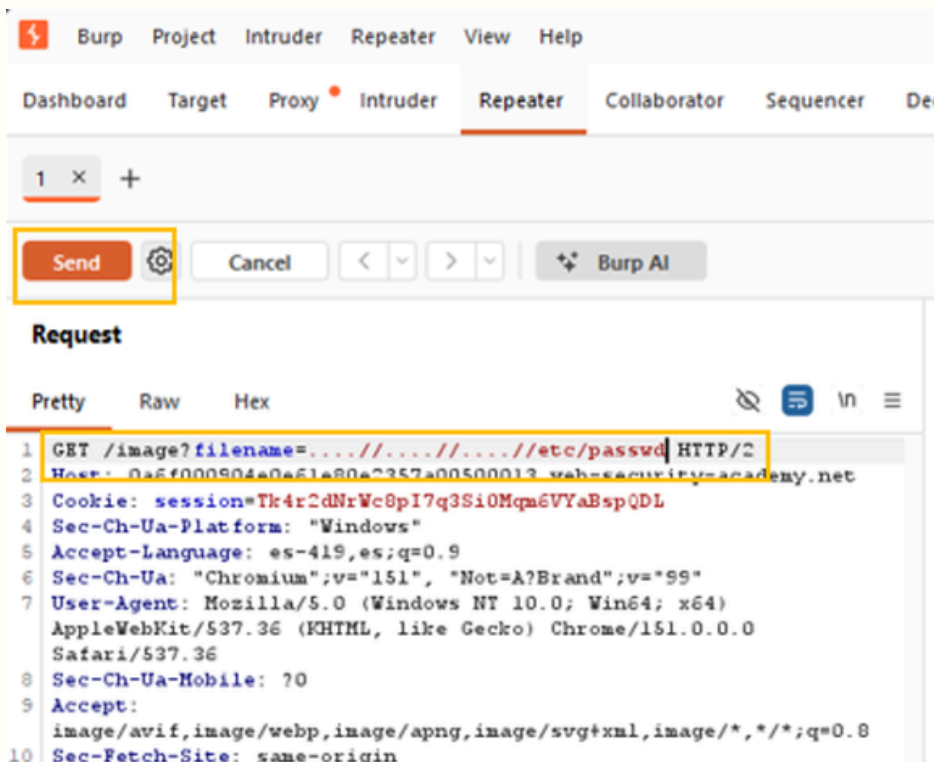
Después de haber ingresado el enlace, nos debemos regresar a BurpSuite, mientras estamos en la pestaña de **Proxy**, en donde debemos de dar clic en **Forward** para que se puedan cargar las diferentes partes de la página en la que estamos trabajando. Seguimos dando clic en **Forward** hasta encontrar un endpoint de una imagen.



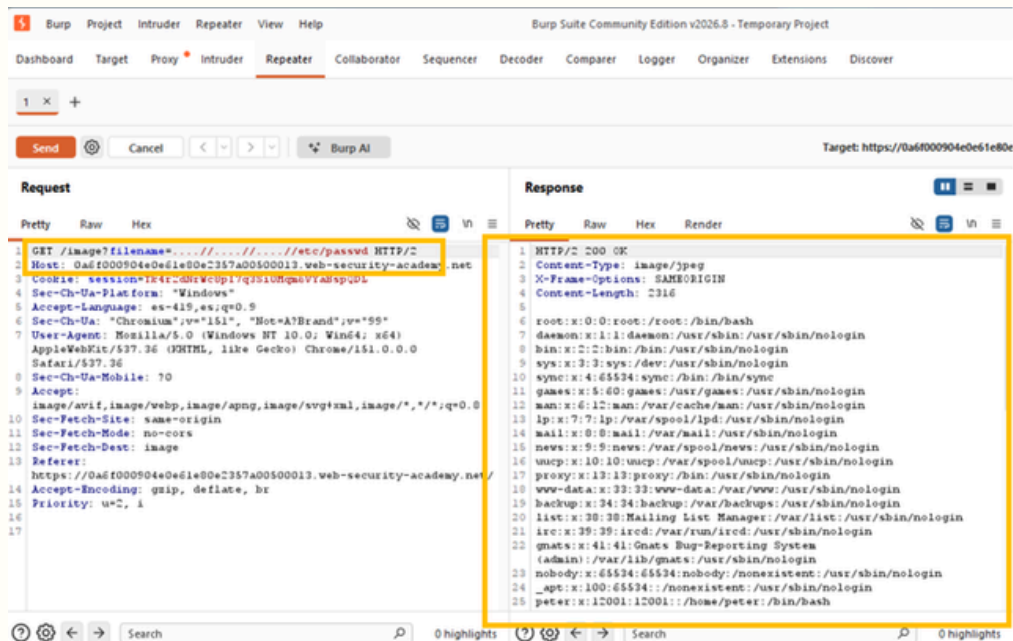
Seleccionamos esa instrucción, para después dar clic derecho, en donde se nos mostrarán diferentes opciones, de las cuáles solo seleccionaremos **Send to Repeater**, lo que es enviar al repetidor para poder cambiar la dirección del archivo a abrir.



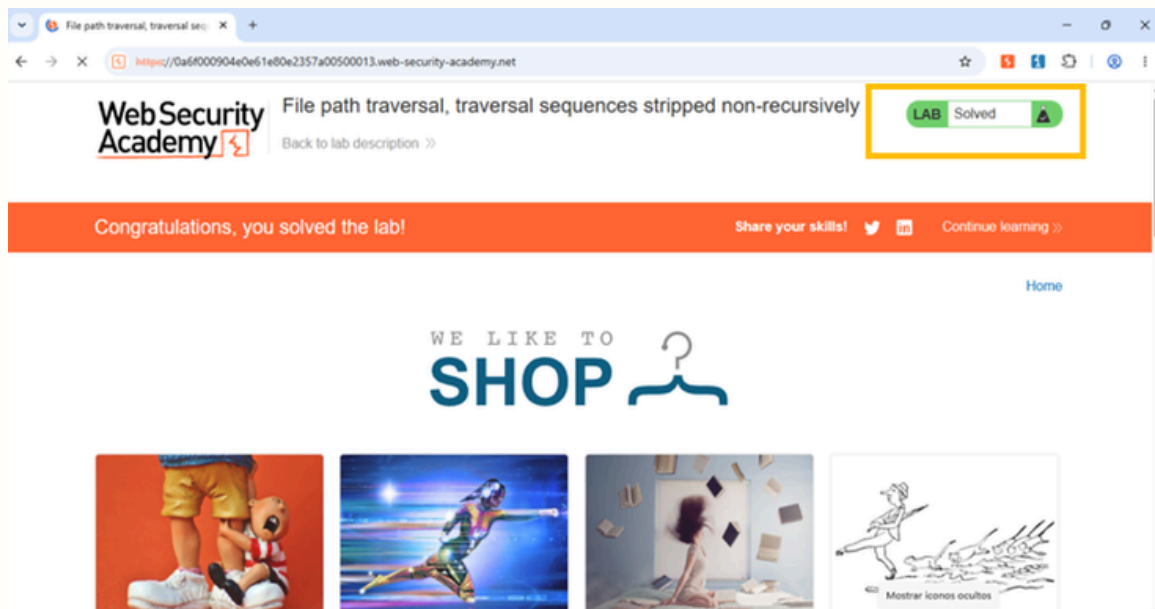
Nos movemos a la pestaña del repetidor, en donde podremos hacer los cambios, en donde en la instrucción deberemos escribir: **GET /image?filename=....//....//....//etc/passwd**. Después de haber modificado la instrucción deberemos dar clic en **Send**, para poder hacer que la instrucción en realidad si se cambie.



Después de haber hecho clic en **Send**, se nos mostrará la información que se encuentra en esa ruta, que es toda la información de las contraseñas y del root.



Cuando se nos muestre esa información podemos dar como concluida nuestra práctica de laboratorio, solo nos queda conformar que se haya actualizado y se nos muestre que ya está resuelto nuestro laboratorio.



Explicación del Payload

El payload es la entrada especialmente modificada que se envía a la aplicación para aprovechar la vulnerabilidad. En este laboratorio se utiliza una secuencia de traversal construida de manera que el filtro elimine una parte de ella, pero después permanezca una secuencia ../ válida.

Esto funciona porque el filtro realiza la eliminación una sola vez y no vuelve a revisar el resultado. De esta forma, el payload consigue modificar la ruta que procesa el servidor y permite solicitar un archivo ubicado fuera del directorio originalmente permitido.

En términos sencillos, el payload busca engañar al filtro para que, después de limpiarlo, todavía exista una ruta de traversal funcional.

Mitigación Recomendada

Para evitar esta vulnerabilidad, no se recomienda simplemente eliminar cadenas como ../, ya que este tipo de filtros pueden ser evadidos. Se recomienda:

- Normalizar y canonicalizar la ruta antes de utilizarla.
- Validar que la ruta resultante permanezca dentro del directorio permitido.
- Utilizar una lista de archivos permitidos (allowlist) cuando sea posible.
- Evitar que el usuario pueda controlar directamente rutas del sistema de archivos.
- Aplicar controles de acceso adecuados para impedir la lectura de archivos sensibles.
- Realizar una validación del lado del servidor, independientemente de las validaciones realizadas en el cliente.